

マスタリングTCP/IP 情報セキュリティ編

認証技術の基礎と主体認証

学籍番号: 1280391

細川夏風

高知工科大学

September 18, 2026

① 認証技術の基礎

- 認証の概念
- アクセス制御

② 主体認証

- 主体認証の概要
- 主体の知識による認証

③ Web 認証 API 認証について

認証技術の基礎

認証技術の基礎

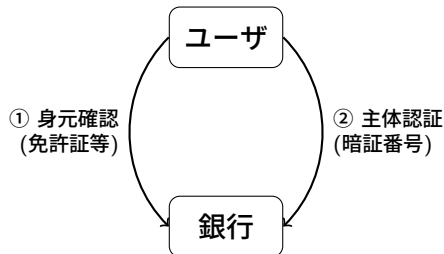
認証の概念

確認と認証

セキュリティではどのユーザをどのリソースに
どういうふうにアクセスさせるか（が）重要。
あらかじめ登録されたものに対して、身元の確
認をすることを，“主体認証”，“認証”という。
認証には主に2つの工程がある。

- ▶ 身元確認: 何かしらの証明書で登録の際に
ユーザの情報を確かめる。
- ▶ 主体認証: 利用する際に以前の情報から認
証を行う。

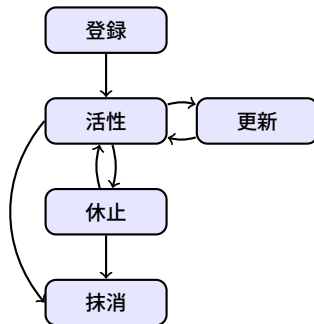
例として，銀行が挙げられる。



認証に関する用語

- ▶ 登録: ID をシステムに新規登録した状態.
- ▶ 活性: 認証が許可され, ID が利用可能な状態.
- ▶ 更新: 異動などに伴い, 権限や属性を変更する.
- ▶ 休止: 長期休暇などで一時的に利用を停止する.
- ▶ 抹消: 退職などに伴い, ID をシステムから削除する.

この用な ID のライフサイクルの管理を IdM: Identity Management という.



認証技術の基礎

アクセス制御

アクセス制御

特定のユーザ (ID) に対して権限を付与することによってユーザの動作を制御することができる。これを“アクセス制御”という。これを一覧表にしたものをアクセス制御リスト (ACL: Access Control List) という。

アクセス制御の例

- ▶ 任意アクセス制御 (DAC: Discretionary Access Control) は、所有者が、誰に読ませるか誰に書き込ませるかを自由に決められる仕組み。
- ▶ 強制アクセス制御 (MAC: Mandatory Access Control) は、システム管理者が決めたルールに従って、システムが強制的にアクセスを制限する仕組み。
- ▶ ロールベースアクセス制御 (RBAC: Role-Base Access Control) は、直接権限を付与するのではなく役割を通して権限を付与する方式。

主体認証

主体認証

主体認証の概要

主体認証の種類

- ▶ 主体の知識による認証
- ▶ 主体の所持するものによる認証
- ▶ 主体の身体的な特性による認証

下の2つは人を対象にした認証方式である。

これらの要素を併用して用いられる際には“多要素認証”と呼ばれるが厳密な定義は不明。さらに近年では、“多段階認証”が導入されているケースが多い。これは1度の認証が完了するとさらに次に違う方式の認証で2度目の認証を行う方式である。

主体認証

主体の知識による認証

主体の知識による認証

現在認証に使われている認証技術に主に以下の3つがある。

- ▶ パスワード認証
- ▶ パスフレーズ認証
- ▶ PIN: Personal Identification Number

基本的にはパスワード、パスフレーズのセキュリティ強度は「長さ」、「使われている文字の種類」、「ランダム性」に大きく依存する。しかし、書籍にはパスワードとパスフレーズのセキュリティ強度は大きく差がないとされている。

パスワードとパスフレーズの違い

パスワードは1単語低度であるのに対し、パスフレーズは20文字以上を及ぶ文字列であることが必要。

パスワードに関する事

NIST ガイドライン

- ▶ SHALL / SHALL NOT: しなければならない, してはならないの従うべき項目.
- ▶ SHOULD / SHOULD NOT: すべきである, すべきでないの推奨, 非推奨の項目.
- ▶ MAY / NEED NOT: してもよい, しなくてもよいの許容行動の項目.

これらのガイドラインを用いて, パスワード自体の構成要件やパスワードの前処理要件, 保存に関する要件が NIST のガイドラインで定められている. 興味ある方は是非.

> <https://openid-foundation-japan.github.io/800-63-3-final/sp800-63b.ja.html>

認証に使うパスワードは平文で保存しないこと. ハッシュ関数などの一方向関数を使用して暗号文で保存することが強く推奨されている.

NTLM 認証は現在幾つかの脆弱性で windows 側が用いていない可能性がある。

NTLM 認証の脆弱性を狙った代表的な攻撃手法として、以下の3つが挙げられる。

- ▶ パス・ザ・ハッシュ攻撃 (Pass-the-Hash: PtH) 端末のメモリ等から盗み出したパスワードの「ハッシュ値」を、そのまま別のサーバーへの認証に使い回す手法。
- ▶ NTLM リレー攻撃 (NTLM Relay Attack) 被害者からの認証要求 (通信) を途中で横取りし、別の標的サーバーへそのまま中継することで、不正にアクセス権を奪う手法。
- ▶ オフライン・クラッキング ネットワーク上の認証トラフィックを盗聴・保存し、手元の環境で解析ツールを用いて元のパスワードを復元する手法。

現在の主流な Windows 認証方式

NTLM の脆弱性を克服するため、現在ではより安全な以下の認証方式が主に利用されている。

- ▶ Kerberos(ケルベロス) 認証 Windows 2000 以降の Active Directory 環境でデフォルトとなっている方式。チケットと呼ばれる仕組みを利用して安全に認証を行う。
- ▶ モダン認証 (Microsoft Entra ID など) クラウド環境の普及に伴い主流となった、SAML や OpenID Connect を利用する方式。多要素認証 (MFA) を前提とした強固なセキュリティを持つ。
- ▶ パスワードレス認証 (FIDO2 など) Windows Hello for Business に代表される、生体認証 (顔や指紋) や PIN を利用し、パスワード自体をネットワーク上に一切流さない仕組み。

ワンタイムパスワード

ワンタイムパスワード (OTP) 認証の際に 1 度だけのパスワードを用いて認証を行う方式のことである。実現方法は以下の 2 つ存在する。

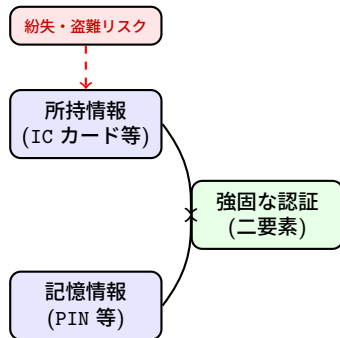
一つが最初にシード値を一方向関数に入れ、その出力を何度も一方向関数に入れることによってそれぞれの値を組として利用者に渡す。認証の際にはその出力結果の値の組を作成の時の逆の順序で利用していく。これにより、セキュリティ被害を一時的なものにする。

もう一つが一定時間ごとにワンタイムパスワードを生成する方式である。

主体の所持するものによる認証

IC カードやハードウェアトークンなどの実際に利用者が所持しているものを用いて認証を行う。パスワード等より強固な認証を行うことが可能である。

これにも問題があり、紛失や盗難などで勝手に利用されるケースが存在するので、さらにPIN などを用いて対策する必要がある。



身体的特徴による認証 (生体認証)

主体の身体的特徴を用いて認証を行う方式を「生体認証 (Biometric Authentication)」という。パスワード等の記憶や持ち物を必要とせず、主に以下の4種類が広く実用化されている。

主な身体的特徴と認証の仕組み

- ▶ 指紋 (Fingerprint) 認証 指先の紋様 (隆線の分岐点や端点など) のパターンをセンサで読み取る方式。
- ▶ 顔 (Face) 認証 目, 鼻, 口の配置や骨格の立体的な形状をカメラや赤外線センサで解析する方式。
- ▶ 静脈 (Vein) 認証 近赤外線を照射し, 指や手のひらの皮下にある血管パターンを読み取る方式。体内情報のため偽造が極めて困難である。
- ▶ 虹彩 (Iris) 認証 眼球の瞳孔の周囲にある虹彩 (しわの複雑な模様) を解析する方式。経年変化がほぼなく, 双子でも異なるため非常に精度が高い。

Web 認証 API 認証について

API 認証について

今回 Web 技術で用いられる認証として API 認証がある。これは API を誰でも叩ける状態にしないためのものだ、幾つかの

主な API 認証の種類

- ▶ API キー: サービス側が発行した文字列をヘッダや URL パラメータに貼り付ける方法。
- ▶ Basic 認証: ユーザ ID とパスワードを Base64 でエンコードしてヘッダに貼り付ける方法。
- ▶ OAuth: 認証サーバからのアクセストークンで通信を行う仕組み。Google や GitHub など著名なものが用いられることが多い。
- ▶ JWT(Json Web Token): Json 形式で誰のトークンがいつまで有効かを定めたものをヘッダや Cookieなどで管理する方式。